

Pratica S5/L1

Obbiettivo:

Raccogliere informazioni in modalità passiva da fonti aperte e analizzarle con l'ausilio di script Python e intelligenza artificiale. Attività:

- Eseguire interrogazioni DNS e consultare i record WHOIS su un dominio a scelta
- Sfruttare combinazioni di Google Dorking per individuare documenti o directory esposti (se presenti)

Dominio scelto:

“penny.it”

Punto 1 “Interrogazione DNS e consulta dei record WHOIS”:

Da terminale Kali abbiamo lanciato il comando “**WHOIS penny.it**” che ci dà a chi appartiene il dominio, il registrar, la data di registrazione, di scadenza e i Name Server (NS) associati. generando i seguenti risultati:

Per interrogare il DNS abbiamo lanciato i seguenti comandi sempre su terminale Kali: “dig penny.it A, dig penny.it MX e dig penny.it TXT”

dig penny.it A: ci fornisce gli indirizzi IPv4 del server web

dig penny.it MX: ci fornisce i server che gestiscono la posta elettronica

: spesso contengono record di verifica (SPF, DKIM) che elencano altri servizi di terze parti autorizzati.

dig penny.it A:

```
Session Actions Edit View Help
(kali@kali)-[~]
$ dig penny.it A

; <<>> Dig 9.20.23-1-Debian <<>> penny.it A
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 65395
;; flags: qr rd ra ad; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 0

;; QUESTION SECTION:
;penny.it.                IN      A

;; ANSWER SECTION:
penny.it.                 3584    IN      A      34.49.253.169

;; Query time: 7 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Tue Jul 07 03:00:01 EDT 2026
;; MSG SIZE rcvd: 42
```

dig penny.it MX:

```
(kali@kali)-[~]
$ dig penny.it MX

; <<>> Dig 9.20.23-1-Debian <<>> penny.it MX
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 64746
;; flags: qr rd ra; QUERY: 1, ANSWER: 2, AUTHORITY: 3, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;penny.it.                IN      MX

;; ANSWER SECTION:
penny.it.                 3600    IN      MX      10 mxa-009d0501.gslb.pphosted.com.
penny.it.                 3600    IN      MX      10 mxb-009d0501.gslb.pphosted.com.

;; AUTHORITY SECTION:
penny.it.                 86400   IN      NS      ns1.veniceplaza.net.
penny.it.                 86400   IN      NS      ns2.veniceplaza.net.
penny.it.                 86400   IN      NS      ns3.veniceplaza.net.

;; Query time: 51 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Tue Jul 07 03:00:25 EDT 2026
;; MSG SIZE rcvd: 181
```

dig penny.it TXT:

```
Session Actions Edit View Help
(kali@kali)-[~]
$ dig penny.it TXT

; <<>> Dig 9.20.23-1-Debian <<>> penny.it TXT
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 49476
;; flags: qr rd ra; QUERY: 1, ANSWER: 11, AUTHORITY: 3, ADDITIONAL: 1

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags:; udp: 4096
;; QUESTION SECTION:
;penny.it.                IN      TXT

;; ANSWER SECTION:
penny.it.                 3600    IN      TXT      "MS=ms10473628"
penny.it.                 3600    IN      TXT      "MS=EC70A27CB0035A22747C06AF577377DCB6DD0173"
penny.it.                 3600    IN      TXT      "v=spf1 redirect=c68df4a7e85fb1824273a5c4f87b3cae41a0ecdffc1ef55850a354be7.eu.rspf.letsdmarc.com"
penny.it.                 3600    IN      TXT      "MS=ms82756214"
penny.it.                 3600    IN      TXT      "google-site-verification=5ifDzqx4L-8fSjH3zRXAVFR61F-Dj404vtlH8a6m09o"
penny.it.                 3600    IN      TXT      "google-site-verification=a03IfFAn-lmZTGbctQMcZKLEOf2Hn1Nyiwl1KacHq8U"
penny.it.                 3600    IN      TXT      "cisco-ci-domain-verification=705e5389af987f1bc37956c585d0feb0bc9b9a7d59f20b6a53bfc1d0799c6826"
penny.it.                 3600    IN      TXT      "atlassian-domain-verification=rWCxzKFqoqrYzN9TZpsXZUsSVjOaRMh3aR8UL7wwXCMbz8zFYvLZEFPrAHY1tdn"
penny.it.                 3600    IN      TXT      "hhj55v3rhj2fzbn67043wz6vw422ngc"
penny.it.                 3600    IN      TXT      "9524z7ty6dc5svr1lg4w2exp77wmt"
penny.it.                 3600    IN      TXT      "_bb9z76ezdb97lxxk9nl14bcglo9s9q"

;; AUTHORITY SECTION:
penny.it.                 86400   IN      NS      ns2.veniceplaza.net.
penny.it.                 86400   IN      NS      ns1.veniceplaza.net.
penny.it.                 86400   IN      NS      ns3.veniceplaza.net.

;; Query time: 99 msec
;; SERVER: 192.168.1.1#53(192.168.1.1) (UDP)
;; WHEN: Tue Jul 07 03:00:49 EDT 2026
;; MSG SIZE rcvd: 831
```

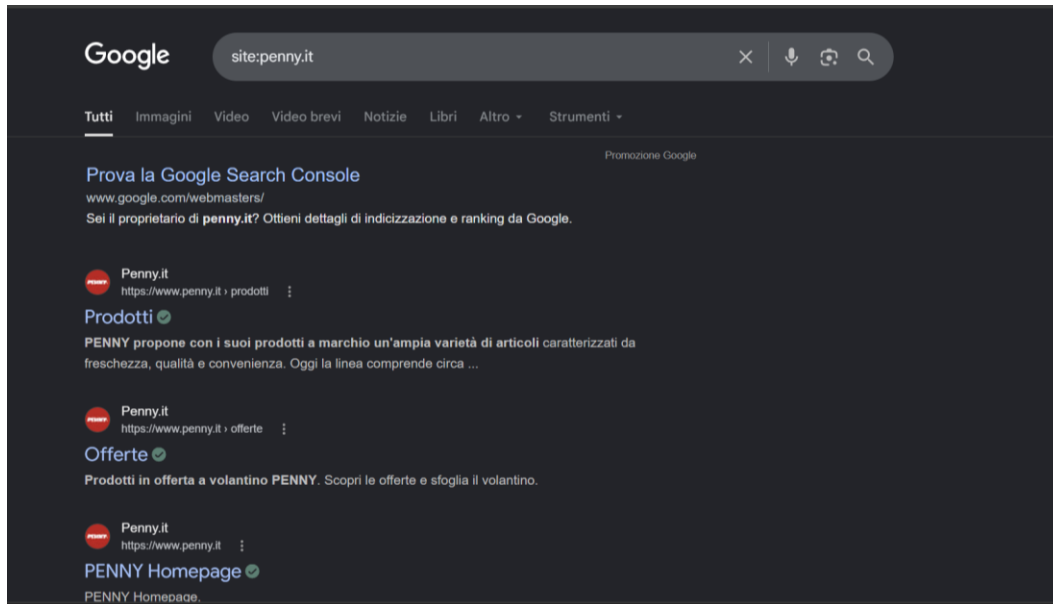
Punto 2 “Sfruttare combinazioni di Google Dorking”:

Qui usiamo gli operatori avanzati di Google per costringere il motore di ricerca a

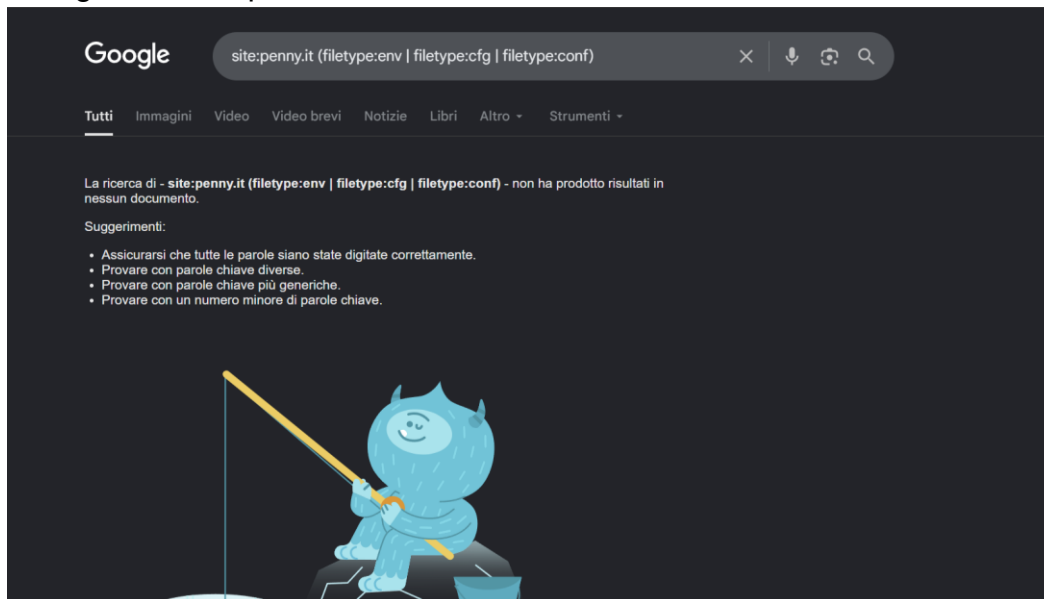
mostrarci cose che ha indicizzato ma che forse l'amministratore del sito voleva tenere nascoste.

Abbiamo usato i seguenti comandi:

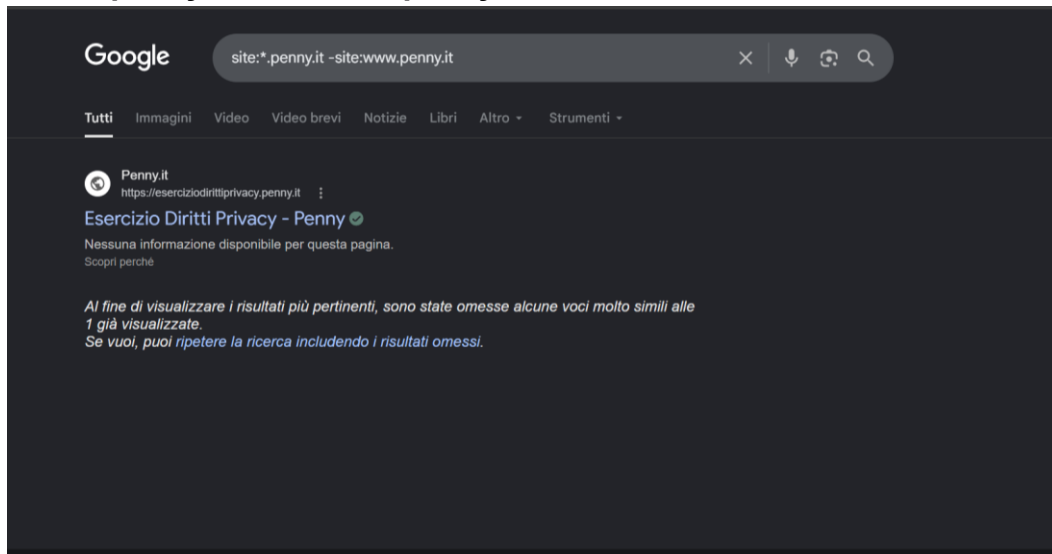
“site:penny.it” : tutto quello che cerca sta in quel determinato dominio



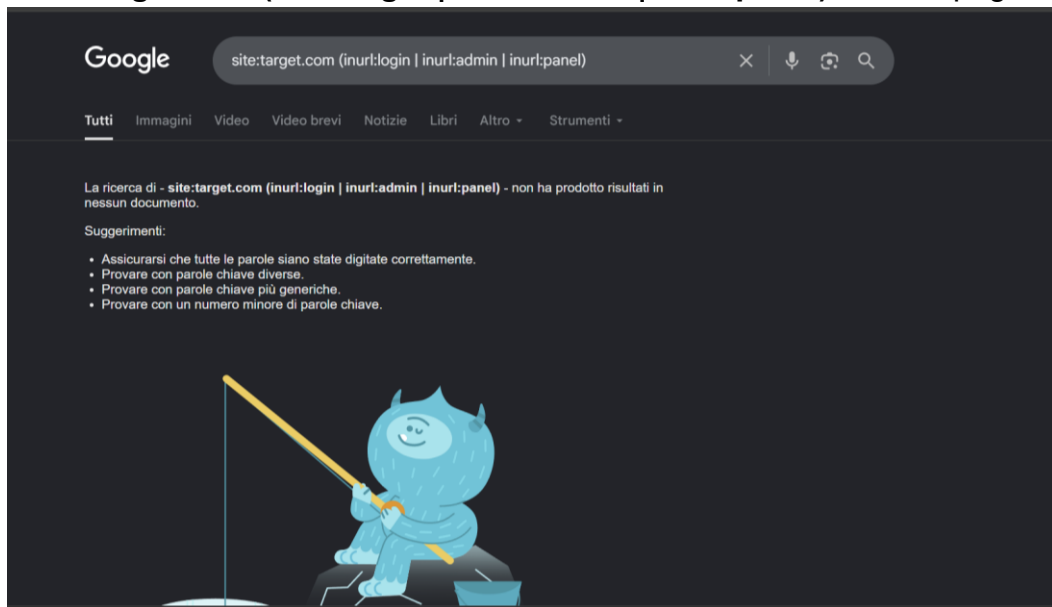
“site:penny.it (filetype:env | filetype:cfg | filetype:conf)” : trova file di configurazioni esposti



“site:*.penny.it -site:www.penny.it” : trova i sottodomini



“site:target.com (inurl:login | inurl:admin | inurl:panel)” : trova pagine di login



EXTRA:

Sviluppare uno script Python capace di raccogliere log DNS e invocare le API di Gemini per sintetizzare i risultati

Il programma è uno script di **Security Automation** sviluppato in Python. Il suo scopo è automatizzare la fase di **Reconnaissance passiva (OSINT)** su un dominio target e utilizzare l'Intelligenza Artificiale per analizzare istantaneamente i risultati, simulando il lavoro di un analista di cybersecurity.

Abbiamo ottenuto il seguente risultato:

```
Session Actions Edit View Help
[osint-env] (~/osint-env)
$ python importdns.py
/home/kali/osint-env/importdns.py:21: FutureWarning:
All support for the 'google.generativeai' package has ended. It will no longer be receiving
updates or bug fixes. Please switch to the 'google.gemai' package as soon as possible.
See README for more details.
https://github.com/google-gemini/deprecated-generative-ai-python/blob/main/README.md

import google.generativeai as genai
Inizio raccolta DNS passiva su: penny.it
Inviamo i dati a Gemini per l'analisi Specialistica...

=====
REPORT DI ANALISI GENERATO DA GEMINI
=====

Eccellente set di dati grezzi per un'analisi OSINT e di Cyber Security. Procediamo con l'analisi del dominio 'penny.it'.

---

### Analisi DNS di 'penny.it'

#### 1. Provider di Terze Parti Evidenti

L'analisi dei record DNS rivela una dipendenza significativa da diversi provider di servizi cloud e di sicurezza di terze parti.

* **Google Cloud Platform (GCP):**
  * **Evidenza:** Il record A '34-46-253-189' appartiene a Google Cloud.
  * **Nota:** Indica che il sito web principale di 'penny.it' è ospitato su Google Cloud.
* **Proofpoint:**
  * **Evidenza:** I record MX puntano a '*.gib.pphosted.com', che è il dominio di Proofpoint.
  * **Nota:** Gestione della sicurezza e del routing della posta elettronica in ingresso. Questo suggerisce che 'penny.it' utilizza Proofpoint per la protezione antispam, antivirus e forse per la prevenzione del phishing a livello di gateway email.
* **Let'sDMARC:**
  * **Evidenza:** Il record TXT SPF utilizza un 'redirect' a '*.eu.rspf.letsdmarc.com'.
  * **Nota:** Gestione della policy SPF (Sender Policy Framework) e, molto probabilmente, della policy DMARC (Domain-based Message Authentication, Reporting, and Conformance), anche se un record DMARC esplicito non è presente in questi dati. Let'sDMARC è specializzato nell'autenticazione delle email e nel reporting DMARC.
* **Microsoft (365 / Azure AD):**
  * **Evidenza:** Record TXT 'MS= ('MS=C706A27C8B35A22747C6AF57377DC600D17A', 'MS=msr2756214', 'MS=ms10473628').
  * **Nota:** Questi sono record di verifica del dominio utilizzati da Microsoft per servizi come Microsoft 365 (precedentemente Office 365) o Azure Active Directory. Suggerisce che l'organizzazione utilizza l'ecosistema Microsoft per la posta elettronica, la collaborazione (es. Teams, SharePoint) o la gestione delle identità, anche se l'MX è esterno.
* **Cisco:**
  * **Evidenza:** Record TXT 'cisco-ci-domain-verification...'.
  * **Nota:** Indica un'integrazione con un servizio cloud di Cisco. Potrebbe trattarsi di Cisco Umbrella (sicurezza DNS), Cisco Secure Email Cloud Gateway (ex IronPort, anche se MX è Proofpoint, potrebbe essere per outbound o analisi), o altri servizi di sicurezza o infrastruttura cloud di Cisco.
* **Atlassian:**
  * **Evidenza:** Record TXT 'atlassian-domain-verification...'.
  * **Nota:** Indica che l'organizzazione utilizza prodotti Atlassian (es. Jira, Confluence, Bitbucket, Trello) e ha verificato il dominio per la gestione degli utenti o per altri servizi integrati.
* **Google (Search Console/Analytics/Workspace):**
  * **Evidenza:** Record TXT 'google-site-verification...'.
  * **Nota:** Utilizzato per verificare la proprietà del dominio con i servizi Google, come Google Search Console (per SEO e performance del sito), Google Analytics, o anche Google Workspace (sebbene meno comune per la sola verifica generica).

#### 2. Configurazioni di Sicurezza

* **SPF (Sender Policy Framework):**
  * **Evidenza:** Presente e configurato.
  * **Nota:** Il record TXT 'v=spf1 redirect=80d4a7e85fb2d27235c4f87b3caab4edcd1ef5585a334be7.eu.rspf.letsdmarc.com.' L'uso di 'redirect' a LetsDMARC è una pratica comune per gestire politiche SPF complesse e superare i limiti di 10 lookup DNS, delegando la gestione a un servizio specializzato. Questo è un buon segno di un'attenta gestione dell'autenticazione delle email in uscita.
  * **DKIM (DomainKeys Identified Mail):**
    * **Evidenza:** Non rilevato.
    * **Nota:** Non ci sono record TXT che iniziano con 'domainkey' o un selettore DKIM specifico.
    * **Implicazioni:** La mancanza di DKIM è una significativa lacuna di sicurezza per l'autenticazione delle email. DKIM aggiunge una firma crittografica alle email, garantendo che il contenuto non sia stato alterato in transit e che provenga da un mittente autorizzato. Senza DKIM, le email di 'penny.it' sono più suscettibili a spoofing e attacchi di phishing che potrebbero non essere intercettati solo tramite SPF.
  * **DMARC (Domain-based Message Authentication, Reporting, and Conformance):**
    * **Evidenza:** Non rilevato.
    * **Nota:** Non c'è un record TXT con il prefisso '_dmarc'.
    * **Implicazioni:** La mancanza di DMARC è un'altra «grave lacuna». DMARC si basa su SPF e DKIM per fornire una politica di come i server di ricezione devono gestire le email che falliscono questi controlli (es. rifiutare, mettere in quarantena) e, fondamentale, per inviare report ai proprietari del dominio su tentativi di spoofing o errori di autenticazione. Senza DMARC, 'penny.it' non ha visibilità sugli abusi del proprio dominio di posta elettronica e non può imporre politiche di rifiuto, lasciando gli utenti finali più vulnerabili a email fraudolente che utilizzano il loro dominio.
  * **Record TXT "Sospetti" / Informazioni Rilevanti:**
    * **Evidenza:** Record TXT '_b0976e2d907f4a39b14b601a9594..._h3j5v3rjb2fz3m67843wz6wa22gc', '_952a77y6dc3vvr1g2w42ecp7mw'.
    * **Nota:** Questi sono stringhe alfanumeriche apparentemente casuali. Potrebbero essere ulteriori record di verifica per servizi interni o meno comuni, o per strumenti di monitoraggio/analisi specifici. Non sono intrinsecamente "sospetti" nel senso di dannosi, ma rappresentano un'informazione in più per un attaccante che cerca di identificare l'intera superficie tecnologica dell'organizzazione (fingerprinting).
    * **Nota:** I numerosi record di verifica (Google, MS, Cisco, Atlassian) non sono sospetti, ma forniscono una mappa dettagliata dei servizi cloud utilizzati dall'azienda, facilitando la fase di ricognizione per un attaccante mirato.

#### 3. Sintesi Esecutiva Finale: Superfici d'Attacco e Livello di Hardening

* **Superfici d'Attacco Potenziali:**
  1. **Email Spoofing/Phishing:** Questa è la superficie d'attacco più critica e evidente. La mancanza di DKIM e DMARC rende il dominio 'penny.it' altamente vulnerabile a tentativi di spoofing. Attaccanti potrebbero facilmente inviare email che sembrano provenire da 'penny.it' (ad esempio, da dirigenti, reparto HR, IT) per scopi di phishing, frodi BEC (Business Email Compromise) o diffusione di malware, con alte probabilità che queste email superino i filtri di autenticazione dei destinatari. Nonostante SPF sia presente, la sua efficacia è limitata senza DKIM e DMARC per una protezione completa e l'applicazione di politiche.
  2. **Riconoscimento Approfondito del Stack Tecnologico:** La presenza di numerosi record di verifica (Google, Microsoft, Cisco, Atlassian) fornisce agli attaccanti un quadro dettagliato dei fornitori di servizi cloud utilizzati. Questo permette di concentrare gli sforzi di attacco su vulnerabilità note o configurazioni errate specifiche di queste piattaforme, o di mirare a credenziali relative a questi servizi (es. phishing per credenziali Microsoft 365 o Atlassian).
  3. **Compromissione di Terze Parti:** La dipendenza da molteplici fornitori di terze parti (GCP, Proofpoint, LetsDMARC, Microsoft, Cisco, Atlassian) introduce il rischio di supply chain. Una breccia nella sicurezza di uno di questi fornitori, o una configurazione errata da parte loro, potrebbe avere un impatto diretto sulla sicurezza di 'penny.it'.
* **Livello di Hardening del Dominio:**
  * **Punti di Forza:**
    * **Hosting Sicuro:** L'utilizzo di Google Cloud Platform per l'hosting del sito web indica una scelta per un'infrastruttura moderna e generalmente sicura.
    * **Sicurezza Email Inbound:** L'implementazione di Proofpoint per i record MX è un'ottima pratica per proteggere la posta elettronica in ingresso da spam, malware e phishing.
    * **Gestione SPF Professionista:** SPF configurato a 'redirect' a LetsDMARC mostra un'attenzione alla gestione dell'autenticazione delle email in uscita, anche se incompleta.
    * **Adozione di Strumenti Enterprise:** L'integrazione con Microsoft 365, Cisco e Atlassian suggerisce un'organizzazione che investe in strumenti professionali e una certa maturità IT.
  * **Punti Deboli:**
    * **CRITICA - Email Authentication Incompleta:** La mancanza di DKIM e DMARC è il punto debole più significativo. Senza questi, l'autenticazione delle email è gravemente compromessa, lasciando il dominio e i suoi destinatari vulnerabili.
    * **Riconoscimento Facile:** Mentre la trasparenza è spesso necessaria, l'abbondanza di record di verifica TXT rende relativamente facile per un attaccante costruire un profilo dettagliato dello stack tecnologico di 'penny.it' durante la fase di ricognizione.
* **Conclusione Esecutiva:**
  Il dominio 'penny.it' mostra una base infrastrutturale moderna e un'adozione significativa di servizi cloud e di sicurezza di terze parti per diverse funzioni aziendali (hosting, email inbound, collaborazione). Ciò suggerisce un certo livello di investimento in tecnologia e sicurezza. Tuttavia, il livello di hardening della posta elettronica è gravemente carente a causa dell'assenza di DKIM e DMARC. Questa lacuna rappresenta una superficie d'attacco elevata per attacchi di spoofing e phishing che sfruttano l'identità del dominio. Un attaccante potrebbe facilmente impersonare 'penny.it' nelle comunicazioni email.
  Raccomandazione immediata: È fondamentale implementare DKIM e DMARC con una policy di enforcement (inizialmente 'quarantine', poi 'reject') il prima possibile per mitigare il rischio di frodi via email e migliorare drasticamente la reputazione del dominio e la sua resilienza agli attacchi di phishing. La presenza di LetsDMARC e Proofpoint dovrebbe semplificare notevolmente questa implementazione.
```